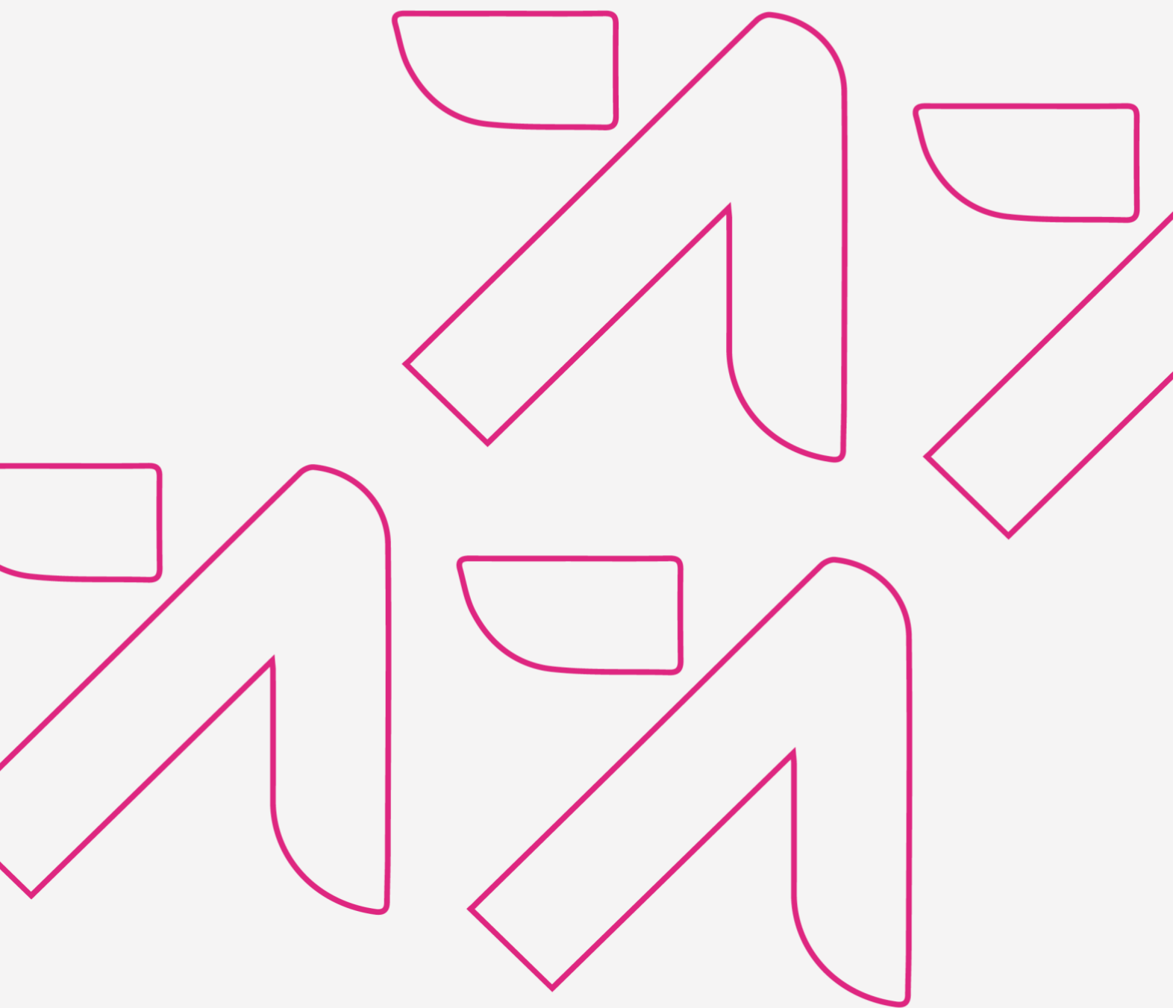




Máster de

# Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

## Tema 8. Implementación de medidas de ciberseguridad y respuesta a incidentes

**Encaje en el curso 2026/2027:** tema 8 del temario oficial, dentro del RA4. Los apartados 5 a 7 refuerzan lo que piden los criterios del RA4 y el temario oficial trata de pasada: procedimientos de actuación, restablecimiento de servicios y documentación.

### 1. Políticas de seguridad

Las medidas técnicas no se sostienen sin un marco que diga qué se protege, quién es responsable y cómo se decide.

#### 1.1. Jerarquía documental

| Nivel               | Qué dice                                         | Ejemplo                                 |
|---------------------|--------------------------------------------------|-----------------------------------------|
| Política            | Qué se quiere y por qué; la aprueba la dirección | Política de seguridad de la información |
| Normativa           | Reglas concretas de obligado cumplimiento        | Norma de uso de contraseñas             |
| Procedimiento       | Cómo se hace, paso a paso                        | Procedimiento de alta de usuarios       |
| Instrucción técnica | El detalle para un sistema concreto              | Guía de bastionado de servidores Linux  |

#### 1.2. Plan director de seguridad

Es la hoja de ruta: parte de la situación actual, define a dónde se quiere llegar y ordena los proyectos para conseguirlo.

1. Conocer la situación actual: activos, riesgos, cumplimiento.
2. Conocer la estrategia de la organización.
3. Definir proyectos e iniciativas.
4. Clasificarlos y priorizarlos por riesgo, coste y esfuerzo.
5. Aprobación por la dirección.
6. Puesta en marcha y seguimiento.

#### 1.3. El ciclo PDCA

Un sistema de gestión de seguridad de la información (SGSI) funciona en ciclo continuo:

- **Planificar (Plan):** analizar riesgos, fijar objetivos y elegir controles.
- **Hacer (Do):** implantar los controles y documentarlos.
- **Verificar (Check):** medir, auditar y revisar incidentes.
- **Actuar (Act):** corregir y mejorar.

Cada incidente es una entrada directa a la fase de verificación: indica qué control faltó o falló.

## **2. Normas y buenas prácticas**

### **2.1. ISO/IEC 27001**

Norma internacional certificable para un SGSI. La versión vigente (2022) recoge 93 controles en cuatro bloques: organizativos, de personas, físicos y tecnológicos. Entre ellos hay un grupo específico para la gestión de incidentes: planificación, evaluación de eventos, respuesta, aprendizaje y recopilación de evidencias.

### **2.2. Esquema Nacional de Seguridad**

Obligatorio para el sector público y sus proveedores tecnológicos. Clasifica los sistemas en categoría básica, media o alta y fija las medidas para cada una; la gestión de incidentes y la continuidad forman parte del marco operacional.

### **2.3. Otras referencias**

NIS2 para entidades esenciales e importantes, RGPD y LOPDGDD para datos personales, e ISO 22301 para la continuidad de negocio.

## **3. Protección del puesto de trabajo**

- Sistema y aplicaciones actualizados de forma automática.
- Usuarios sin permisos de administrador.
- Antimalware o EDR gestionado de forma centralizada.
- Disco cifrado y bloqueo automático de pantalla.
- Control de dispositivos USB y de software instalable.
- Mesas limpias: ni contraseñas en notas adhesivas ni documentos a la vista.
- Navegador y cliente de correo bastionados.

## **4. Almacenamiento de la información**

### **4.1. En la red corporativa**

- Los datos de trabajo viven en servidores o en la nube corporativa, no en los equipos.
- Permisos por grupos y con mínimo privilegio; revisión periódica.
- Clasificación de la información: pública, interna, confidencial.
- Registro de accesos a las carpetas sensibles.

### **4.2. En los equipos y soportes**

- Solo lo imprescindible y siempre cifrado.

- Soportes extraíbles cifrados y registrados.
- Borrado seguro antes de reutilizar o desechar un equipo.

#### 4.3. En la nube

Responsabilidad compartida: el proveedor protege la infraestructura; la configuración, los accesos y los datos son cosa del cliente. Compartir «con cualquiera que tenga el enlace» es el origen de muchas fugas.

### 5. Procedimientos de actuación

Un procedimiento de actuación (playbook) es la respuesta ya pensada para un tipo de incidente. En plena crisis no hay tiempo para decidir desde cero.

#### 5.1. Qué contiene

| Apartado     | Contenido                                        |
|--------------|--------------------------------------------------|
| Disparador   | Qué alerta o aviso lo activa                     |
| Triaje       | Cómo confirmar y qué gravedad asignar            |
| Contención   | Acciones, quién las ejecuta y quién las autoriza |
| Erradicación | Cómo eliminar la causa                           |
| Recuperación | Cómo y en qué orden se vuelve a la normalidad    |
| Comunicación | A quién se avisa, dentro y fuera                 |
| Evidencias   | Qué hay que conservar                            |
| Cierre       | Criterios para darlo por terminado               |

#### 5.2. Los imprescindibles

Phishing con credenciales robadas, malware en un equipo, ransomware, cuenta comprometida, pérdida o robo de dispositivo, fuga de datos y denegación de servicio.

### 6. Erradicación y restablecimiento de servicios

#### 6.1. Erradicación

- Eliminar el malware y los mecanismos de persistencia: cuentas creadas, tareas programadas, servicios, claves.
- Corregir la vulnerabilidad o el error de configuración que permitió la entrada.
- Cambiar todas las credenciales que hayan podido verse expuestas, incluidas las de servicio.
- Ante la duda, reinstalar desde una imagen limpia: es más fiable que limpiar.

## 6.2. Recuperación

- Restaurar desde copias anteriores al compromiso y comprobadas. Restaurar una copia ya infectada devuelve al atacante.
- Seguir el orden de prioridad que marca el análisis de impacto: primero lo que el negocio necesita antes.
- Aplicar parches y bastionado antes de reconectar.
- Volver por fases, no todo a la vez.

## 6.3. Verificación

- Pruebas funcionales con los usuarios.
- Análisis de vulnerabilidades del sistema restaurado.
- Vigilancia reforzada durante las semanas siguientes: los atacantes vuelven a intentarlo.

## 7. Documentar el incidente

Cada incidente deja un expediente con, al menos:

- Identificador, fechas de inicio, detección, contención y cierre.
- Clasificación, peligrosidad e impacto.
- Descripción y línea temporal.
- Sistemas, cuentas y datos afectados.
- Acciones realizadas, por quién y cuándo.
- Evidencias recogidas y su cadena de custodia.
- Notificaciones efectuadas.
- Causa raíz y medidas correctivas, con responsable y plazo.

Sin este registro no hay métricas, ni lecciones aprendidas, ni forma de demostrar diligencia ante un regulador.

## 8. Continuidad de negocio

### 8.1. Análisis de impacto en el negocio (BIA)

Identifica los procesos críticos y cuánto tiempo puede aguantar la organización sin cada uno. De ahí salen dos cifras por servicio:

- **RTO (tiempo objetivo de recuperación):** cuánto se puede estar parado como máximo.
- **RPO (punto objetivo de recuperación):** cuántos datos, medidos en tiempo, se pueden perder como máximo.

| Servicio          | RTO     | RPO        | Implica                                      |
|-------------------|---------|------------|----------------------------------------------|
| Tienda en línea   | 2 horas | 15 minutos | Réplica en otra ubicación y copias continuas |
| Correo            | 8 horas | 4 horas    | Servicio en la nube con alta disponibilidad  |
| Archivo histórico | 5 días  | 24 horas   | Copia diaria y restauración manual           |

## 8.2. Plan de continuidad de negocio (PCN)

Describe cómo seguir trabajando durante una crisis: equipo de crisis, procedimientos alternativos, sedes y proveedores de respaldo, y plan de recuperación de los sistemas. Un plan que no se ha ensayado es solo un documento.

## 8.3. Copias de seguridad

- Regla **3-2-1**: tres copias, en dos soportes distintos, una fuera de la sede.
- Al menos una copia inmutable o desconectada, fuera del alcance de un ransomware.
- Cifradas y con acceso restringido.
- Probadas: una copia que no se ha restaurado nunca no es una copia.
- Las copias en la nube añaden ubicación externa, pero hay que revisar retención, cifrado y dónde se almacenan.

### Para ampliar

- ISO/IEC 27001 e ISO/IEC 27002: requisitos y controles de un SGSI.
- ISO 22301: sistemas de gestión de la continuidad de negocio.
- INCIBE: Plan director de seguridad y guía de copias de seguridad para empresas.
- CCN-CERT: guías de buenas prácticas frente al ransomware.